

COMPUTER SOCIETY OF KENYA

GROUP CASE STUDY

OPERATION NGAO:

Enterprise Security Under Kenya's Data Protection Act

Classification: SIMULATION | Difficulty: Mid-level | Duration: 3 Hours

EXERCISE OVERVIEW

Format

Group simulation & presentation

Total Duration

3 hours (90 min work + 30 min present + 60 min debrief)

Skills Assessed

- Creative problem-solving
- Technical security knowledge
- Leadership under pressure
- Legal and regulatory reasoning
- Team decision-making

SECTION 1: BACKGROUND & SCENARIO

1.1 Regulatory Context

Kenya's Data Protection Act (DPA) 2019 came into full force in November 2019 and is enforced by the Office of the Data Protection Commissioner (ODPC). It mandates that all entities handling personal data of Kenyan citizens must register as data processors or data controllers, implement technical and organizational safeguards, and report data breaches within 72 hours. Non-compliance carries penalties of up to KES 5 million or imprisonment.

Despite this framework, many Kenyan enterprises — from fintech startups in Nairobi's Silicon Savannah to county government systems — are still in various stages of compliance adoption, creating a critical window of vulnerability.

1.2 The Organisation: SawaConnect Ltd.

ATTRIBUTE	DETAILS
Company	SawaConnect Ltd. — a mid-size fintech and mobile-credit provider
Headquarters	Upper Hill, Nairobi; regional offices in Mombasa, Kisumu, and Eldoret
Staff	470 full-time employees + ~200 remote agents
Customers	1.8 million registered users across Kenya, Uganda, and Tanzania
Data Handled	National ID numbers, phone numbers, M-Pesa transaction records, credit scores, biometric selfies, and location data
Infrastructure	Hybrid cloud (AWS East Africa + on-premises servers at HQ); legacy USSD systems still used for ~35% of transactions
Compliance Status	Registered with ODPC (2021); Data Protection Officer appointed but under-resourced; last security audit was 18 months ago

1.3 The Incident—Operation Ngao Begins

It is Monday, 07:43 EAT. SawaConnect's IT helpdesk receives a flood of tickets: customers cannot log into the mobile app, agents report that the internal CRM is responding slowly, and the fraud detection system has gone silent. The CEO has just been forwarded a dark-web forum post — in Swahili and English — that reads:

"Tunayo data yako. SawaConnect wamesalimisha data ya wateja wao 1.8M. Tutawasiliana ndani ya masaa 48 — au tutauza. We have your data. SawaConnect has exposed 1.8M customer records. We will be in touch within 48 hours — or we sell. #OperationNgao"

By 09:00, the Head of IT has confirmed that an unknown external IP accessed SawaConnect's database cluster for approximately 6 hours overnight through a compromised vendor API key. The accessed tables include customer PII, transaction histories, and a partial batch of encrypted biometric data.

The ODPC clock is now ticking. The board, investors, regulators, and 1.8 million customers are watching.

SECTION 2: YOUR TEAM ROLES

Each group must assign the following roles before beginning. Every role has veto power on decisions in their domain. Roles cannot be shared — one person, one role.

ROLE	TITLE AT SAWACONNECT	PRIMARY RESPONSIBILITY IN THIS EXERCISE
Incident Commander	CEO / MD	Leads all decisions, manages stakeholder communication, and makes final calls on trade-offs. Accountable to the board.
Security Lead	Head of Cybersecurity	Technical investigation: attack vector analysis, containment strategy, forensic integrity.
Data Protection Officer	DPO	Regulatory compliance: DPA 2019 obligations, ODPC notification drafting, lawful basis assessment.
Communications Lead	Head of PR & Corp. Comms	Drafts internal and external communications; manages media narrative; advises on crisis messaging.
Legal Counsel	Company Advocate	Legal exposure assessment — DPA liability, potential civil suits, third-party vendor contracts.
Risk & Continuity Officer	Head of Enterprise Risk	Business continuity: assessing financial, reputational, and operational risk. Guides resource allocation.

NOTE: Groups of 4 may merge the Legal Counsel role into the DPO, and the Risk Officer role into the Incident Commander. Document which roles were merged and how responsibilities were divided.

SECTION 3: CHALLENGE TASKS

Complete all four challenges within 90 minutes. Each challenge builds on the previous. Allocate your time carefully — partial answers score better than skipped questions.

CHALLENGE 1 | FIRST 2 HOURS: TRIAGE & CONTAINMENT

Time box: 20 minutes | Points: 25

The Security Lead has identified three possible attack vectors that could explain the breach. The incident commander must decide on a containment approach—without full information—before the morning's board call at 10:00.

Possible Attack Vectors (pick the most likely and justify)

#	Vector	Evidence Fragment
---	--------	-------------------

A	Compromised vendor API key (third-party integration)	Logs show access from IP 154.113.x.x (Lagos, NG) via the CreditCheck API endpoint at 01:17 EAT. The API key belongs to a credit bureau partner.
B	Insider threat — privileged database admin account	A DBA's credentials were used to query 14 tables between 01:00 – 07:00 EAT. The DBA was on leave but says their laptop was at home.
C	Unpatched vulnerability in legacy USSD middleware	The middleware server (last patched 14 months ago) shows unusual outbound traffic to an AWS S3 bucket not owned by SawaConnect.

Your Tasks — Challenge 1

- 1.1** Identify which attack vector (A, B, or C) your team believes is the PRIMARY breach cause. Justify with at least three technical or contextual reasons.
- 1.2** Design a 2-hour containment playbook (bullet-point steps, in order) that shuts down active data exfiltration without taking the entire platform offline — SawaConnect must keep M-Pesa integrations live.
- 1.3** What forensic evidence must be immediately preserved before any system is touched? Name at least five artefacts and explain why each matters.
- 1.4** The DBA (Vector B suspect) has arrived at the office. The Incident Commander must decide: isolate the DBA immediately or allow them to assist the investigation? Write a one-paragraph decision memo with reasoning.

CHALLENGE 2 | DPA 2019 COMPLIANCE — THE 72-HOUR CLOCK

Time box: 25 minutes | Points: 30

Kenya's DPA 2019 requires notification of personal data breaches to the ODPC within 72 hours. You are now at Hour 2. The DPO must take the lead.

DPA 2019 Quick Reference (provided in exercise)

DPA REQUIREMENT	DETAIL
Section 43 — Breach Notification	Must notify ODPC within 72 hours of becoming aware; must notify affected data subjects "without undue delay" if high risk.
Section 25 — Security of Processing	Data controllers must implement appropriate technical and organisational measures to ensure data security, including pseudonymisation and encryption.
Section 31 — Data Processor Liability	A data controller is liable for the acts of its data processors (vendors, partners) unless they can prove the processor acted outside instructions.
Section 72 — Penalties	On conviction: KES 3 million (first offence) up to KES 5 million (repeat). ODPC can also order deletion, suspension of processing, or public notice.

Your Tasks — Challenge 2

5. **2.1** Draft the ODPC breach notification letter (Hour-2 version). Include: nature of breach, categories of data affected, approximate number of data subjects, likely consequences, and measures taken. Be precise — the ODPC will scrutinise vague language.
6. **2.2** Identify ALL categories of personal data that were potentially exposed (from the scenario), classify each by sensitivity level (Low / Medium / High / Special Category under DPA), and state what harm could result from its exposure for each.
7. **2.3** SawaConnect's credit bureau partner (Vector A) is a data processor. Under Section 31 DPA, is SawaConnect liable for the partner's compromised API key? Build the legal argument FOR and AGAINST liability.
8. **2.4** Design the customer notification message (SMS + in-app). It must be truthful, not cause panic, meet the DPA standard, and be written at a literacy level appropriate for all 1.8M customers, many of whom use feature phones.
9. **2.5** The DPO is told by the CEO: 'Let's wait until Hour 60 to notify — we need to be sure of the facts.' What is the DPO's correct course of action? Is partial notification permissible under DPA 2019?

CHALLENGE 3 | DILEMMAS ROUND — PRESSURE-TEST YOUR DECISIONS

Time box: 25 minutes | Points: 25

Real-world security crises are full of uncomfortable choices. Your team must reach consensus on each dilemma and appoint a spokesperson to defend your position during the presentation. There are no universally 'correct' answers — you are judged on reasoning quality, not outcome.

Dilemma A — Pay or Fight?

At Hour 6, the threat actor makes contact via encrypted email and demands KES 15 million (approx. USD 116,000) to delete the data and provide a proof-of-deletion report. Your cyber insurance covers up to KES 20 million. Paying may recover the data but signals weakness and potentially funds criminal enterprise. Not paying risks 1.8M customer records going on sale.

- **Task:** Should SawaConnect pay the ransom? Provide your recommendation with at least four reasons.
- **Task:** Who in your team has authority to approve this payment, and what governance process must be followed?
- **Task:** How does paying (or not paying) affect your ODPC notification obligations and potential DPA liability?

Dilemma B — The Journalist's Call

At Hour 10, a reporter from a major Kenyan news outlet calls the Communications Lead. They have seen the dark-web post and are running a story in 2 hours — with or without SawaConnect's comment. The full extent of the breach is still being assessed; you have not yet notified the ODPC.

- **Task:** What does the Communications Lead say? Draft the exact statement (max 80 words).

- **Task:** Does disclosing to the media before the ODPC constitutes a DPA violation? Discuss.
- **Task:** What is the Incident Commander's role in approving or vetoing this communication?

Dilemma C — The Cross-Border Data Problem

Forensic analysis reveals that 340,000 of the exposed records belong to Ugandan and Tanzanian customers. Both countries have their own data protection laws (Uganda's PDPA 2019, Tanzania's Personal Data Protection Act 2022). SawaConnect has no dedicated DPO for those markets.

- **Task:** Map out SawaConnect's obligations to each of the three regulators (Kenya ODPC, Uganda PDPC, Tanzania PDPC). Are timelines different?
- **Task:** Propose a 30-day cross-border compliance roadmap for SawaConnect to avoid triple-jurisdiction penalties.

Dilemma D — The Legacy System Trap

The Security Lead confirms that Vector C (USSD middleware vulnerability) is a contributing factor — an attacker pivoted from the patched API gateway through the unpatched USSD middleware. The middleware vendor says a patch will take 3 weeks. Switching it off protects data but cuts off ~35% of transactions (primarily rural, low-income users).

- **Task:** Should the USSD system be shut down pending patching? Frame this as a risk vs. access-to-financial-services dilemma.
- **Task:** Design a compensating control that keeps the USSD system conditionally live while reducing risk by at least 70%. Be specific.

CHALLENGE 4 | POST-INCIDENT: BUILDING A RESILIENT FUTURE

Time box: 20 minutes | Points: 20

The immediate crisis is contained. Now build the security architecture SawaConnect should have had — and create a roadmap to get there within 12 months on a constrained budget.

Your Tasks — Challenge 4

10. **4.1** Identify the top 5 root-cause security failures that made this breach possible. For each, name the gap, the DPA section it violates, and the fix.
11. **4.2** Design a 12-month Enterprise Security Roadmap for SawaConnect. Organise it in three phases (Stabilise → Strengthen → Sustain). Each phase must include: technical controls, people/process controls, and a DPA compliance milestone.
12. **4.3** SawaConnect wants to build a Security Operations Centre (SOC) but has a budget of KES 8 million for Year 1. Present a build vs. buy vs. hybrid recommendation with cost estimates and trade-offs relevant to the Kenyan market.
13. **4.4** Propose a Data Minimisation and Retention Policy that would have reduced the blast radius of this breach. Reference DPA 2019 Section 25 in your answer.

- 14.4.5 The ODPC has asked SawaConnect to submit a corrective action plan within 30 days. Draft the executive summary of that plan (max 200 words).

SECTION 4: PRESENTATION & SCORING

4.1 Presentation Format

Each group has 30 minutes: 20 minutes to present findings + 10 minutes Q&A from the panel. All roles must speak. Use the following structure:

15. Incident Brief (2 min) — Incident Commander summarises what happened and what decisions were made.
16. Technical Response (5 min) — Security Lead walks through containment, forensics, and the chosen attack vector.
17. Regulatory Compliance (5 min) — DPO presents ODPC notification and DPA analysis.
18. Dilemmas (5 min) — Spokesperson defends the group's position on at least 2 of the 4 dilemmas.
19. Future Roadmap (3 min) — Risk & Continuity Officer presents the 12-month plan.

4.2 Scoring Rubric

DIMENSION	WHAT JUDGES LOOK FOR	MAX PTS	WEIGHT
Technical Accuracy	Correct security concepts, realistic controls, forensic integrity	25	25%
Regulatory Compliance	Accurate DPA 2019 references, notification quality, lawful reasoning	30	30%
Decision Quality	Clear reasoning, acknowledgement of trade-offs, ethical awareness	25	25%
Teamwork & Leadership	Role clarity, equal participation, cohesive narrative, handling Q&A under pressure	20	20%
TOTAL		100	100%

4.3 Bonus Points (up to 10 additional)

- Team proposes a creative solution not hinted at in the brief (e.g., a novel compensating control, an innovative customer trust initiative): +3 points
- Team identifies a DPA 2019 requirement NOT explicitly mentioned in the exercise and correctly applies it: +3 points
- Team's ODPC notification draft is judged to be submission-ready by the panel: +4 points

SECTION 5: FACILITATOR NOTES

This section is for facilitators only. Do not distribute to participants until the debrief.

Intended Learning Outcomes

- Participants understand Kenya's DPA 2019 breach notification obligations in a realistic, time-pressured setting.
- Participants practise the tension between technical containment speed and regulatory precision.
- Participants develop language to navigate the ransom, media, and cross-border dilemmas that Kenyan enterprises face.
- Participants experience leadership under incomplete information — a core enterprise security reality.

Key Debrief Discussion Points

20. 'What made it hardest to agree within your 'team?'—Surface the tension between legal, technical, and business perspectives.
21. 'Was your ODPC notification complete enough at Hour '2?'—Often groups over-wait; introduce the concept of partial notification.
22. 'Who had the most influence in your team — the role or the person?' — Leadership discussion.
23. 'What would you have done differently if this were a real organisation you worked for?' — Personalise the learning.

Model Answers Overview

There are no single correct answers, but key expectations are the following:

- Vector A (compromised vendor API) is the strongest primary vector; most logs support it. Vector C (USSD middleware) is a contributing factor, not the primary.
- ODPC notification at Hour 2 should be a preliminary notification — Section 43 permits filing with incomplete information where full facts are not yet known, with a supplementary report to follow.
- The ransom payment is not recommended — CBK guidelines and international best practice discourage it; however, credit must be given for teams that argue for payment if they properly address governance and legal disclosure.
- The USSD shutdown is a genuine trade-off; compensating controls such as rate-limiting, additional authentication, and anomaly detection on USSD transactions are acceptable answers.

Reference Materials for Facilitators

- Kenya Data Protection Act, 2019 — Kenya Law

- ODPC Breach Notification Guidelines (2022)—odpc.go.ke
- CBK Cybersecurity Guidelines for Payment Service Providers, 2023
- NIST CSF 2.0 — Incident Response Framework
- ENISA Threat Landscape for Financial Sector

Good luck, teams. Kazi nzuri.

Security is not a product. It is a continuous process — and it starts with people who think, question, and lead.

Computer Society of Kenya | Enterprise Security Programme | 2025